



Hidden Admin



Bối cảnh (Context)

Một công ty phần mềm vừa tạo ra trang quản trị nội dung (CMS). Thay vì xây dựng một hệ thống phân quyền phức tạp, các lập trình viên Frontend lại quyết định bảo mật chức năng bằng cách... dùng CSS để ẩn (`display: none`) các nút bấm dành cho Admin, hoặc dùng trường `type="hidden"` trong form dữ liệu HTML đối với các tài khoản thường.

Họ nghĩ rằng "mắt không thấy thì tìm không đau", người dùng bình thường sẽ không biết có nút bấm đó tồn tại trên trang web.



Mục tiêu (Objective)

- **Nhiệm vụ:** Khám phá các chức năng ẩn hoặc các trường dữ liệu bị che giấu trên trang web để kích hoạt quyền hạn của Admin.
- **Vấn đề / Lỗ hổng: Information Disclosure & Parameter Tampering** (Thao túng tham số). Frontend chỉ che giấu giao diện, trong khi Backend lại không xác thực quyền khi tiếp nhận các Request. Việc thay đổi dữ liệu trong Form ẩn sẽ ảnh hưởng trực tiếp đến hệ thống.
- **Flag:** Tìm và kích hoạt thành công chức năng ẩn để truy xuất Flag.



Gợi ý (Hints)

- Nhấn `Ctrl + U` (View Page Source) hoặc mở tính năng Inspect Element của trình duyệt.
- Tìm kiếm các từ khóa như `hidden`, `admin`, `debug` trong mã HTML.
- Thử sửa đổi value của thẻ `<input type="hidden">` trước khi submit.